



GOVERNANCE DOCUMENT

Risk Management Policy

International Society of Equity Analysts

DOCUMENT VERSION

1.0

DATE APPROVED

1 July 2026

LAST UPDATED

1 July 2026

ADMINISTERED BY

Audit, Risk and Compliance
Committee

Document Control

DOCUMENT OWNER	Audit, Risk and Compliance Committee
APPROVAL AUTHORITY	Governing Council
ADMINISTERED BY	Audit, Risk and Compliance Committee
DATE APPROVED	1 July 2026
LAST UPDATED	1 July 2026
DOCUMENT VERSION	1.0
NEXT REVIEW DATE	1 July 2027
RELATED DOCUMENTS	Ethics Policy Code of Ethics and Standards of Professional Conduct Conflict of Interest Policy Privacy Policy Document Retention Policy Complaints Policy Disciplinary Policy Whistleblower Policy Membership Policy Membership Regulations Member Admission Framework Continuing Professional Development Policy

This document forms part of the official governance framework of the International Society of Equity Analysts (ISEA) and should be read together with the related documents listed above.

Contents

1. Purpose	4
2. Scope and Application	4
3. Risk Management Principles	5
4. Risk Appetite	5
5. Risk Categories	5
6. Risk Identification and Assessment.....	8
7. Risk Register	9
8. Risk Treatment and Mitigation.....	9
9. Risk Ownership	10
10. Control Environment.....	10
11. Risk Reporting and Escalation.....	10
12. Incident Management	11
13. Business Continuity and Resilience	11
14. Insurance	11
15. Third-Party and Outsourcing Risk.....	11
16. Risk Culture and Training	12
17. Responsibilities.....	12
18. Risk Monitoring and Review	13
19. Relationship with Other ISEA Policies	13
20. Breaches.....	14
21. Review and Continuous Improvement	14
22. Effective Date	14

1. Purpose

The International Society of Equity Analysts (ISEA) is committed to identifying, assessing, managing and monitoring risks that could affect the achievement of its objectives, the integrity of its professional standards, the protection of its stakeholders and the sustainability and reputation of the Society.

This Risk Management Policy establishes the principles, responsibilities and processes through which ISEA identifies and manages material risks arising from its governance, operations, professional activities, financial affairs, technology, information management and external environment.

The purpose of this Policy is to:

- promote a systematic and proportionate approach to risk management;
- support informed decision-making by the Governing Council, committees and management;
- protect ISEA's members, candidates, employees, volunteers, partners and other stakeholders;
- safeguard ISEA's assets, information, professional standards and reputation;
- support compliance with applicable legal, regulatory, contractual and governance obligations;
- improve ISEA's resilience to operational disruption, emerging threats and unexpected events; and
- encourage a culture in which material risks are identified and addressed rather than ignored or concealed.

Risk management is an integral part of ISEA's governance and decision-making and is not solely the responsibility of any individual committee or officer.

2. Scope and Application

This Policy applies to ISEA and to persons involved in the management or operation of ISEA, including:

- Governing Council members;
- officers and executives;
- committee members;
- employees and contractors;
- volunteers;
- representatives acting on behalf of ISEA; and
- other persons with responsibility for ISEA activities where relevant.

This Policy applies to risks arising from or affecting:

- governance and organisational decision-making;
- membership and professional designation activities;
- certification, examination, assessment and education programs;
- continuing professional development;
- equity research and professional standards activities;
- events, conferences and professional programs;
- financial management and commercial activities;
- partnerships, sponsorships and external relationships;
- technology, artificial intelligence and digital platforms;
- information security, privacy and data management;
- legal, regulatory and compliance obligations;
- human resources and workplace matters;
- business continuity and operational resilience;
- communications and public reputation; and
- other activities undertaken by or on behalf of ISEA.

This Policy applies to actual, potential and emerging risks and to risks arising from both internal and external sources.

3. Risk Management Principles

ISEA shall apply the following principles in managing risk:

3.1 Proportionate Risk Management

Risk management shall be proportionate to the nature, scale, complexity and potential consequences of the risk.

3.2 Accountability

Responsibility for managing a risk shall be assigned to an appropriate person or body with sufficient authority, competence and resources to manage it.

3.3 Integration

Risk considerations shall be incorporated into strategic planning, policy development, operational decisions, projects, investments and other significant activities.

3.4 Independence of Oversight

Where appropriate, risk identification, management and oversight shall be separated so that significant risks receive objective review.

3.5 Transparency and Escalation

Material risks shall be identified, documented and communicated to the appropriate level of authority. Individuals shall not knowingly conceal, minimise or misrepresent material risks.

3.6 Continuous Improvement

ISEA shall periodically review its risk-management practices and improve them in light of experience, emerging risks, incidents, technological developments and changes in the external environment.

4. Risk Appetite

ISEA shall maintain a risk appetite appropriate to its status as a global professional organisation.

ISEA shall seek to:

- avoid unnecessary risks that could materially compromise its integrity, independence or professional standards;
- accept proportionate and considered risks where doing so supports its strategic objectives and provides reasonable benefits to members or the profession;
- maintain low tolerance for risks involving fraud, corruption, serious ethical misconduct, misuse of confidential information, material breaches of privacy obligations, significant conflicts of interest and conduct that could materially undermine the integrity of ISEA or its professional designations; and
- maintain appropriate controls over financial, operational, technological and reputational risks.

The Governing Council may establish more detailed risk appetite statements or thresholds for specific areas of ISEA's operations.

5. Risk Categories

ISEA shall consider, where relevant, the following categories of risk.

5.1 Strategic Risk

Risks arising from decisions, developments or external circumstances that could prevent ISEA from achieving its strategic objectives.

Examples include:

- ineffective strategic direction;
- failure to maintain professional relevance;
- inappropriate expansion;
- changes in the equity research profession;
- competitive pressures; and
- failure to respond to emerging professional or technological developments.

5.2 Governance Risk

Risks arising from weaknesses in governance, oversight, decision-making or accountability.

Examples include:

- inadequate oversight;
- unclear authority or responsibility;
- conflicts of interest;
- ineffective committee structures;
- poor recordkeeping; and
- failure to follow approved governance requirements.

5.3 Professional and Ethical Risk

Risks arising from conduct that could undermine ISEA's professional standards or the integrity of the equity research profession.

Examples include:

- ethical misconduct;
- plagiarism;
- research manipulation or fabrication;
- conflicts of interest;
- misuse of material non-public information;
- inappropriate use of artificial intelligence;
- misuse of ISEA designations; and
- inadequate enforcement of professional standards.

5.4 Membership and Certification Risk

Risks associated with membership administration, certification, examinations, assessments and professional designations.

Examples include:

- inaccurate membership records;
- inappropriate admission or certification decisions;
- examination integrity failures;
- fraudulent applications;
- misuse of professional designations;
- inconsistent assessment processes; and
- inadequate management of continuing professional development requirements.

5.5 Operational Risk

Risks arising from failures of processes, people, systems or external service providers.

Examples include:

- operational errors;
- inadequate procedures;
- service interruptions;
- key-person dependency;
- supplier failures;
- inadequate business continuity arrangements; and
- failures in event or program administration.

5.6 Financial Risk

Risks that could adversely affect ISEA's financial position, liquidity, assets or sustainability.

Examples include:

- inadequate liquidity;
- inaccurate financial reporting;
- fraud or financial misconduct;
- poor financial controls;
- excessive concentration of revenue;
- investment losses;
- unexpected liabilities; and
- failure of significant counterparties or service providers.

5.7 Legal and Regulatory Risk

Risks arising from non-compliance with applicable laws, regulations, contractual obligations or professional requirements.

Examples include:

- privacy breaches;
- intellectual property infringement;
- regulatory non-compliance;
- contractual disputes;
- employment-related obligations;
- tax obligations; and
- failure to obtain or maintain required permissions or registrations.

5.8 Technology and Cyber Risk

Risks arising from technology systems, digital platforms, artificial intelligence and cyber threats.

Examples include:

- cyberattack;
- unauthorised access;
- data loss;
- system failure;
- inappropriate use of artificial intelligence;
- technology dependency;
- inadequate access controls; and
- failures of third-party technology providers.

5.9 Information and Privacy Risk

Risks arising from inappropriate collection, use, disclosure, retention or protection of personal, confidential or proprietary information.

ISEA shall manage such risks consistently with its Privacy Policy, Information Security requirements, Document Retention Policy and other applicable policies.

5.10 Reputational Risk

Risks that could materially affect confidence in ISEA, its professional standards, its designations or the equity research profession.

Reputational risk may arise from:

- member misconduct;
- governance failures;
- public controversies;
- inadequate communication;
- ethical breaches;
- regulatory action;
- poor service delivery; or
- other events that could materially undermine stakeholder confidence.

5.11 People and Workplace Risk

Risks associated with employees, contractors, volunteers, committee members and other persons working for or on behalf of ISEA.

Examples include:

- inadequate capability or resourcing;
- misconduct;
- harassment or discrimination;
- workplace safety issues;
- key-person dependency;
- inadequate succession planning; and
- loss of critical knowledge.

5.12 External and Emerging Risks

ISEA shall monitor emerging risks arising from developments including:

- artificial intelligence;
- changes in financial markets;
- geopolitical developments;
- economic conditions;
- regulatory changes;
- technological developments;
- changes in professional practice; and
- other external factors that could materially affect ISEA.

6. Risk Identification and Assessment

ISEA shall seek to identify material risks through:

- strategic planning;
- operational reviews;

- committee and management reporting;
- incident and issue reporting;
- audits and assurance activities;
- legal and regulatory reviews;
- consultation with relevant stakeholders;
- scenario and stress analysis where appropriate; and
- monitoring of external developments.

Identified risks shall, where appropriate, be assessed having regard to:

- the likelihood of occurrence;
- the potential impact;
- the speed with which the risk could materialise;
- the effectiveness of existing controls; and
- the resulting residual risk.

ISEA may use a formal risk-rating methodology approved by the Governing Council or an authorised committee.

7. Risk Register

ISEA shall maintain an appropriate risk register or equivalent mechanism for recording material risks.

The risk register should, where appropriate, identify:

- the risk;
- its source or cause;
- potential consequences;
- inherent risk level;
- existing controls;
- residual risk level;
- risk owner;
- planned mitigation measures;
- target risk level;
- review date; and
- status of mitigation actions.

Material risks shall be reviewed at intervals appropriate to their nature and significance.

8. Risk Treatment and Mitigation

ISEA may respond to risks through one or more of the following approaches:

- **Avoidance** — ceasing or not undertaking an activity where the risk is unacceptable;
- **Reduction** — implementing controls to reduce the likelihood or impact of the risk;
- **Transfer** — transferring an appropriate portion of the risk through insurance, contractual arrangements or other mechanisms;
- **Acceptance** — accepting a risk where it falls within ISEA's risk appetite and is appropriately authorised; or
- **Monitoring** — continuing to monitor the risk where further treatment is not presently required.

Risk treatments shall be proportionate to the level and nature of the risk.

Where a risk exceeds ISEA's approved risk appetite, appropriate action shall be taken to reduce, transfer or otherwise address the risk unless acceptance is expressly authorised by the appropriate authority.

9. Risk Ownership

A material risk shall have an identified risk owner.

Risk owners are responsible for:

- understanding the risks within their area of responsibility;
- maintaining appropriate controls;
- monitoring changes in risk exposure;
- implementing agreed mitigation measures;
- reporting material changes or incidents; and
- escalating risks that exceed their authority or risk tolerance.

Delegation of operational responsibility does not remove the accountability of the relevant governing body, committee or executive responsible for the activity.

10. Control Environment

ISEA shall maintain controls reasonably designed to prevent, detect or mitigate material risks.

Controls may include:

- policies and procedures;
- segregation of duties;
- approvals and authorisations;
- access controls;
- reconciliations;
- contractual protections;
- insurance;
- training and awareness;
- monitoring and quality assurance;
- independent review; and
- incident-response procedures.

Controls shall be reviewed periodically to determine whether they remain appropriate and effective.

11. Risk Reporting and Escalation

Material risks shall be reported to the appropriate level of management, committee or the Governing Council having regard to their significance.

Immediate or expedited escalation shall occur where a matter may:

- materially threaten ISEA's financial position or viability;
- materially compromise personal, confidential or material non-public information;
- materially affect certification or examination integrity;
- involve fraud, corruption or serious misconduct;
- result in significant legal or regulatory exposure;
- materially disrupt critical operations; or
- materially damage ISEA's reputation or professional standing.

Reports to the Governing Council should, where appropriate, identify the nature of the risk, potential consequences, existing controls, mitigation measures and recommended actions.

12. Incident Management

ISEA shall maintain processes for identifying, recording, assessing, containing and responding to material incidents.

Where a material incident occurs, ISEA shall, as appropriate:

- take immediate steps to contain the incident;
- protect affected persons, information and assets;
- assess actual and potential consequences;
- notify appropriate internal authorities;
- comply with applicable legal or regulatory notification requirements;
- document the incident and actions taken;
- conduct a post-incident review where appropriate; and
- implement corrective or preventative measures.

Incident management shall operate consistently with applicable ISEA policies, including the Privacy Policy, Information Security Policy, Complaints Policy, Disciplinary Policy and Whistleblower Policy where relevant.

13. Business Continuity and Resilience

ISEA shall maintain proportionate arrangements to support continuity of critical activities following significant disruption.

Business continuity planning should consider:

- critical operations and services;
- key personnel and succession arrangements;
- technology and system dependencies;
- critical suppliers and service providers;
- communications;
- data and records;
- alternative operating arrangements; and
- recovery priorities.

ISEA may periodically test or review its business continuity arrangements.

14. Insurance

ISEA may maintain insurance appropriate to its activities and risk exposure, having regard to:

- the nature and scale of operations;
- contractual requirements;
- legal and regulatory considerations;
- financial resources; and
- the cost and availability of appropriate coverage.

Insurance shall not be treated as a substitute for appropriate risk controls.

15. Third-Party and Outsourcing Risk

Before appointing significant external service providers, ISEA shall consider relevant risks arising from the proposed relationship.

Where proportionate, ISEA may assess:

- financial and operational capability;
- information security and privacy controls;
- legal and regulatory compliance;
- reputation;
- business continuity;
- concentration risk;
- contractual protections; and
- dependence on critical suppliers.

Significant outsourced activities shall be monitored appropriately.

16. Risk Culture and Training

ISEA shall promote a risk-aware culture in which persons responsible for ISEA activities understand their responsibilities for identifying and escalating material risks.

ISEA may provide training or guidance concerning:

- risk identification;
- information security;
- privacy;
- fraud prevention;
- conflicts of interest;
- professional and ethical obligations;
- business continuity; and
- other risk-management matters relevant to particular roles.

Individuals shall not be penalised for raising legitimate concerns about material risks in good faith through appropriate channels.

17. Responsibilities

17.1 Governing Council

The Governing Council has ultimate responsibility for overseeing ISEA's risk-management framework.

The Governing Council shall:

- approve this Policy;
- establish or approve ISEA's overall risk appetite;
- oversee material and strategic risks;
- receive appropriate risk reporting;
- ensure appropriate risk-management arrangements are maintained; and
- review significant risk matters requiring Governing Council attention.

17.2 Audit, Risk and Compliance Committee

Where established, the Audit, Risk and Compliance Committee shall support the Governing Council by:

- monitoring the effectiveness of the risk-management framework;
- reviewing significant risks and mitigation measures;
- reviewing material incidents and emerging risks;
- monitoring financial, compliance and operational risk matters; and
- recommending improvements to the Governing Council.

17.3 Management and Executives

Management and executives are responsible for implementing approved risk-management arrangements within their areas of responsibility.

They shall:

- identify and manage material risks;
- maintain appropriate controls;
- report material risk developments;
- implement mitigation measures; and
- ensure relevant staff and volunteers understand their responsibilities.

17.4 Committees and Other Responsible Persons

Committees, officers, employees, volunteers and representatives are responsible for identifying and appropriately managing risks within their areas of responsibility and escalating material matters through appropriate channels.

18. Risk Monitoring and Review

ISEA shall periodically review its material risks and the effectiveness of relevant controls.

Monitoring may include:

- review of risk-register entries;
- key risk indicators;
- incident trends;
- control assessments;
- audit findings;
- regulatory developments;
- stakeholder feedback; and
- emerging-risk analysis.

Material changes in the risk environment shall be communicated to the appropriate governance body.

19. Relationship with Other ISEA Policies

This Policy should be read together with other ISEA policies, regulations and procedures relevant to risk management, including:

- Ethics Policy;
- Code of Ethics and Standards of Professional Conduct;
- Conflict of Interest Policy;
- Privacy Policy;
- Document Retention Policy;
- Complaints Policy;
- Disciplinary Policy;
- Whistleblower Policy;
- Membership Policy;
- Membership Regulations;
- Member Admission Framework; and
- Continuing Professional Development Policy.

Where another ISEA policy establishes specific requirements for managing a particular risk, those requirements shall apply in conjunction with this Policy.

20. Breaches

Failure to comply with this Policy may result in corrective action, management action or disciplinary action, as appropriate and in accordance with applicable ISEA policies and procedures.

Conduct involving dishonesty, concealment, deliberate misrepresentation, obstruction, misuse of information or other serious misconduct may also constitute a breach of the ISEA Code of Ethics and Standards of Professional Conduct.

21. Review and Continuous Improvement

This Policy shall be reviewed periodically by the Audit, Risk and Compliance Committee, or such other body as the Governing Council may designate.

The review shall consider:

- changes in ISEA's activities and operating environment;
- significant incidents and lessons learned;
- changes in legal or regulatory requirements;
- technological developments, including artificial intelligence;
- emerging risks;
- changes in ISEA's strategic objectives; and
- the effectiveness of existing risk controls.

Amendments to this Policy shall be subject to approval by the Governing Council.

22. Effective Date

This Risk Management Policy takes effect on the date approved by the ISEA Governing Council.